

Arquitetura Zero Trust: Fundamentos, Componentes, Aplicações e Desafios de Implementação

David Lobo, Pedro Rosa, and Esteban Yepez

University of Minho, Department of Informatics, 4710-057 Braga, Portugal
e-mail: {a114812, a116276, a117634}@alunos.uminho.pt

Resumo A Arquitetura Zero Trust representa uma mudança significativa em relação ao modelo tradicional de segurança baseado no perímetro, ao eliminar a confiança implícita concedida a utilizadores, dispositivos e redes internas. Este estudo descreve os conceitos fundamentais da Arquitetura *Zero Trust*, com base nos princípios estabelecidos pelo NIST, apresentando também os seus principais componentes lógicos, tais como o Ponto de Decisão de Política e o Ponto de Aplicação de Política. São também avaliados os pilares técnicos da arquitetura, incluindo a autenticação forte, o controlo de acesso, a avaliação contínua da confiança e a monitorização constante. Além disso, o relatório aborda domínios de aplicação fundamentais, tais como o acesso remoto, o acesso de terceiros, a mitigação de ransomware e os ambientes IoMT. Por fim, são identificados obstáculos à implementação, tais como a latência, a integração com sistemas legados, a complexidade operacional e as limitações em ambientes distribuídos e com recursos limitados.

1 Introdução

A segurança de redes, durante muitos anos, baseou-se no conceito de um perímetro onde a rede é dividida numa zona interna, considerada de confiança, e numa zona externa, considerada hostil. Esta fronteira era defendida por mecanismos como *firewalls*, sistemas de deteção e prevenção de intrusões (IDS/IPS) e redes privadas virtuais (VPN) [1]. Assim, de acordo com esta ideia, a confiança resulta da localização de uma pessoa: qualquer pessoa que se encontre dentro do perímetro é automaticamente considerada de confiança. No entanto, esta premissa já não é sustentável dada a adoção generalizada da *cloud*, a proliferação de dispositivos (incluindo os pessoais e os da Internet das Coisas (IoT)¹), o aumento do teletrabalho e outros fatores que acabaram por contribuir para a dissolução da fronteira da rede. Outro problema desta arquitetura é que uma parte significativa das ameaças tem origem no interior da própria organização [1]. Uma vez ultrapassado o perímetro, um atacante, ou um utilizador legítimo comprometido, pode movimentar-se lateralmente com muito poucas restrições.

Neste contexto surge o conceito de *zero trust*, “nunca confiar, verificar sempre” proposto pela primeira vez em 2010 por John Kindervag com o fim de dar resposta às ameaças internas [3], e foi posteriormente consolidada pelo *National Institute of Standards and Technology* (NIST) na publicação especial SP 800-207, que a define como um conjunto de princípios orientadores para o desenho de sistemas e operações, e não como uma arquitetura única [4]. Na prática, deixa de existir a distinção entre utilizadores internos e externos: todos os pedidos de acesso são autenticados, autorizados e avaliados, independentemente da sua origem. Um exemplo é o projeto BeyondCorp da Google. Este projeto é frequentemente apresentado como um exemplo prático de aplicação dos princípios Zero Trust em ambientes empresariais, ao substituir o acesso baseado na localização de rede por decisões baseadas na identidade do utilizador, no estado do dispositivo e no contexto do pedido [5].

¹ A Internet das Coisas (IoT) refere-se a uma rede de dispositivos físicos, veículos, eletrodomésticos e outros objetos físicos equipados com sensores, software e conectividade de rede, o que lhes permite recolher e partilhar dados. [2]

É necessário que o acesso do utilizador seja totalmente aprovado, bem como todas as credenciais do dispositivo do utilizador. A técnica foi totalmente integrada na rede do Google Office em 2017. Quando o teletrabalho se tornou comum durante a pandemia da COVID-19, revelou-se segura e tornou os recursos vitais prontamente disponíveis. [1].

Apesar do interesse crescente, a investigação sobre a *Zero Trust Architecture* (ZTA) encontra-se ainda numa fase inicial, sendo escassas as implementações documentadas e as medidas quantitativas de desempenho [6]. Este relatório procura contribuir para uma visão estruturada do tema.

2 Fundamentos da Arquitetura Zero Trust

2.1 O conceito de confiança

A confiança é um conceito que antecede a cibersegurança e tem sido objeto de investigação exaustiva nas ciências humanas. A definição mais frequentemente citada, da autoria de Rousseau et al., caracteriza-a como uma condição psicológica que envolve a disposição para aceitar a vulnerabilidade com base em expectativas favoráveis relativamente às intenções ou ao comportamento dos outros [7]. No entanto, esta definição não abrange toda a dinâmica do conceito nos sistemas computacionais, onde a confiança tem sido associada a conceitos como fiabilidade, reputação, risco ou qualidade de serviço, nenhum dos quais é exaustivo [8]. Por esta razão, a literatura tem preferido classificar a confiança com base no contexto.

Burns et al. distinguem entre confiança *explícita*, baseada em critérios objetivos e em informação verificável, e confiança *implícita*, baseada em perceção subjetiva e experiência. A primeira privilegia a segurança, enquanto a segunda promove a praticabilidade [9]. Outra distinção é proposta por Pearson et al., entre a confiança *a longo prazo*, baseada em propriedades a longo prazo, e a confiança *dinâmica*, aplicável apenas a um estado ou contexto específico [10].

O modelo de perímetro reflete uma confiança implícita e duradoura: um indivíduo mantém essa confiança até que seja reavaliada, o que permite que um *interno* malicioso conserve as suas permissões [1]. O ZTA inverte esta lógica. «Zero» não implica uma ausência total de confiança, mas sim **zero confiança implícita**: a confiança é inicialmente concedida de forma explícita, com a granularidade mínima essencial, dependente do contexto e sujeita a avaliação constante [1].

2.2 Princípios da Zero Trust Architecture

O NIST organiza a ZTA em sete princípios (*tenets*), que concretizam a premissa “nunca confiar, verificar sempre” [4]:

1. Todas as fontes de dados e serviços informáticos são considerados recursos.
2. Todas as comunicações devem ser protegidas, independentemente da localização na rede.
3. O acesso aos recursos individuais da empresa é concedido numa base por sessão.
4. O acesso é determinado por políticas dinâmicas baseadas em identidade, dispositivo, aplicação, comportamento e outros atributos contextuais.
5. A organização monitoriza continuamente o estado de segurança dos seus ativos.
6. A autenticação e autorização são aplicadas dinamicamente antes do acesso.
7. A organização recolhe informação contínua sobre ativos, tráfego, comunicações e contexto para melhorar decisões futuras.

Estes princípios podem ser resumidos em duas ideias: o acesso é determinado por recurso e por sessão, e a confiança concedida varia consoante o contexto e é reavaliada ao longo do tempo, em consonância com o conceito de confiança explícita e dinâmica descrito

na Secção 2.1 [1]. Fernandez e Brazhuk observam que, na prática, as propostas de ZTA incorporam, pelo menos, os princípios clássicos de Saltzer e Schroeder relativos ao sistema fechado, ao privilégio mínimo e à mediação total [6].

2.3 Modelo lógico do NIST

Para além dos princípios, o NIST sugere um modelo lógico que inclui componentes funcionais, os quais, segundo Fernandez e Brazhuk, representam uma síntese do trabalho já realizado até ao ano de 2020 [6].

Os principais componentes são os seguintes:

- **Ponto de Decisão de Política (PDP).** Este é o núcleo do plano de controlo e é responsável pela autenticação e autorização, concedendo acesso com base num nível de confiança que satisfaça as políticas do sistema [1]. Está dividido em dois componentes:
 - o *Mecanismo de Política* (PE), que toma a decisão final de conceder, negar ou revogar o acesso, utilizando um algoritmo de confiança [6];
 - o *Administrador de Políticas* (PA), que executa a decisão do PE — ou seja, estabelece ou encerra o caminho de comunicação entre o sujeito e o recurso, gera credenciais de sessão ou *tokens* e configura o PEP [11].
- **Ponto de Aplicação de Políticas (PEP).** É o núcleo do plano de dados. Interage com o sujeito, encaminha os pedidos de acesso para o PDP e autoriza, monitoriza e encerra a ligação entre o sujeito e o recurso [1,11].

Além disso, o modelo distingue entre duas áreas. O indivíduo encontra-se numa área não confiável e só após a decisão do PDP e a aplicação pelo PEP é que é estabelecido um canal de comunicação dentro de uma zona de confiança implícita, que deve ser tão limitada quanto possível.

O PE não toma decisões de forma isolada. Recebe informações de várias fontes de dados, incluindo o sistema de diagnóstico e mitigação contínuos (CDM), informações sobre a conformidade com as normas do setor, *feeds de inteligência de ameaças*, registos de atividade, diretrizes de acesso a dados, a infraestrutura de chave pública (PKI), o sistema de gestão de identidades e o sistema de gestão de informações e eventos de segurança (SIEM) [6,11]. Com base nestes dados, o algoritmo de confiança determina o valor utilizado na decisão, um tema que será abordado na Secção 3.

O modelo apresenta também limitações identificadas na literatura. Fernandez e Brazhuk observam que não esclarece em que momento cada entrada é tida em conta, nem como certas fontes — tais como o SIEM ou a conformidade com normas — são utilizadas, e que a distinção entre o plano de dados e o plano de controlo é um aspeto da implementação e não de um modelo conceptual [6]. Os mesmos autores observam ainda que o PDP do NIST combina as funções de tomada de decisão, gestão e informação do XACML e utiliza políticas relativamente simples, como o RBAC ou o ABAC [6].

3 Pilares técnicos fundamentais e avaliação de confiança

Os pilares técnicos fundamentais e a avaliação de confiança da (ZTA) são especificados da seguinte forma:

3.1 Autenticação de Identidade

A ZTA exige uma autenticação robusta e dinâmica para todos os pedidos de acesso. A IEEE recomenda a adoção de *Single Sign-On* (SSO) baseado na cloud juntamente com Autenticação Multifator (MFA) para proteger o acesso dos utilizadores [12]. Adicionalmente, as identidades das máquinas e dispositivos (como portáteis, telemóveis e software) também têm de ser rigorosamente estabelecidas, identificadas e catalogadas. O acesso às aplicações e serviços baseia-se no nível de confiança resultante da combinação da identidade do dispositivo, da sua integridade e da autenticação do utilizador.

3.2 Controlo de Acesso

O acesso aos recursos empresariais é autorizado e concedido apenas para completar tarefas específicas, aplicando ativamente o princípio do menor privilégio. O controlo das permissões opera sessão a sessão, garantindo que as autorizações são dinâmicas e rigorosamente impostas antes de se permitir o acesso ao recurso. A arquitetura recorre a um Motor de Políticas (*Policy Engine*) que medeia os pedidos e configura redes de sobreposição (*overlay networks*) ou sistemas de micro-segmentação, limitando efetivamente os acessos indevidos e isolando a rede.

3.3 Avaliação de Confiança

A avaliação da confiança é o mecanismo central que mede a fiabilidade das entidades na rede para fundamentar decisões analíticas de acesso. Na ZTA, a confiança tem de ser constantemente conquistada e validada internamente por sistemas que dependem de algoritmos computacionais específicos de confiança. Conforme documentado no estudo sobre o *framework* de segurança GAZETA publicado na IEEE Xplore, a arquitetura calcula uma pontuação de confiança (*trust score*) baseada em múltiplas métricas que variam perante alterações de ambiente [13].

3.4 Avaliação Contínua

No paradigma Zero Trust, a confiança é um estado transitório e condicional, rejeitando a ideia de que a validação no momento do *login* concede um livre-trânsito para a sessão inteira.

- **Reavaliação Constante:** A confiança estabelecida inicialmente não é definitiva. Após o primeiro acesso, o sistema exige provas contínuas de que o utilizador e o dispositivo se mantêm fidedignos ao longo de toda a interação com a infraestrutura.
- **Monitorização e Registo (Logging):** A visibilidade total é um requisito obrigatório. As organizações devem monitorizar a postura de segurança e a integridade de todos os ativos de forma ininterrupta. Isto implica a recolha e registo exaustivo de dados (*logs*) sobre o tráfego da rede, o estado das comunicações e o comportamento dos utilizadores, permitindo reavaliar a infraestrutura ao mais pequeno sinal de anomalia.
- **Mecanismos Matemáticos:** Em ambientes complexos, a velocidade e precisão necessárias para recalcular os níveis de risco em tempo real ultrapassam a capacidade de regras estáticas. Em algumas propostas avançadas, a avaliação de confiança pode ser complementada por algoritmos superiores, recorrendo a modelos de *Machine Learning* e lógica difusa (*fuzzy logic*). Estas tecnologias analisam padrões de comportamento, classificam desvios e reajustam a pontuação de confiança de forma dinâmica e automatizada.

3.5 Impacto na Infraestrutura

A reavaliação contínua pode aumentar a carga computacional da infraestrutura, uma vez que os pedidos de acesso exigem autenticação, autorização, verificação contextual e aplicação de políticas. Este processo pode introduzir latência adicional, sobretudo em ambientes com grande volume de tráfego ou aplicações sensíveis ao tempo de resposta. No entanto, este custo deve ser analisado em conjunto com os benefícios obtidos, como maior visibilidade, redução da superfície de ataque, limitação do movimento lateral e resposta mais rápida a comportamentos anómalos.

4 Domínios de aplicação

Para descrever melhor o modelo antigo de segurança de redes, é usada a analogia do castelo. Rodeado por muralhas, o castelo é visto como um lugar seguro, impenetrável, onde o que estiver no interior é visto como algo confiável e o que estiver no exterior, algo não fidedigno. Na analogia, o castelo, a muralha e o exterior representam, respetivamente, a rede local (LAN), a *Firewall* e a internet pública. A muralha tornou-se insuficiente e quem tivesse acesso ao interior teria acesso a tudo. A ZTA procura mitigar este problema ao reduzir a confiança implícita e ao limitar o movimento lateral dentro da rede.

- **Acesso Remoto Seguro:** Antigamente, os trabalhadores de escritório tinham uma ligação física para a rede local de uma empresa. Ao surgir a possibilidade de trabalhar remotamente, uma das credenciais de segurança – estar ligado à rede fisicamente – tornou-se inviável. Ciberataques podiam acontecer caso o computador de alguém a navegar por casa fosse infetado por *malware*. Para evitar este tipo de problema, a ZTA implementa o princípio do privilégio mínimo, o que permite aos colaboradores trabalharem apenas com os recursos estritamente necessários para concluírem as suas tarefas.
- **Acesso de Entidades Externas:** Caso uma empresa contrate um consultor externo ou uma outra empresa para trabalhar na manutenção de software/hardware, essa entidade externa também obtém acesso à rede. Neste caso, não se trata de um trabalhador com um acesso limitado, mas sim, historicamente, de acesso total. Para reduzir o risco de um ciberataque, essa entidade externa terá esse privilégio de acesso restrito e por tempo limitado e, além disso, as suas ações serão rigorosamente auditadas e monitorizadas.
- **Mitigação de Ransomware:** *Ransomware* é um tipo de *malware* onde o atacante encripta os dados com o objetivo de extorquir o utilizador. Isto é alcançado, muito frequentemente, através de táticas de engenharia social, como o *phishing*. O *phishing* utiliza táticas de manipulação (por exemplo, mensagens fraudulentas) para instalar *malware* no sistema da vítima. O método para mitigar a propagação do problema é a microsegmentação. A microsegmentação divide uma rede em várias zonas de segurança rigorosas. Estas zonas, sem permissão explícita, não conseguem comunicar entre si. Desta forma, no caso de um ataque, apenas uma zona fica infetada, garantindo a segurança das restantes.

5 Desafios de implementação

Apesar das suas vastas vantagens na mitigação de ameaças e na proteção de dados, a adoção da Arquitetura Zero Trust (ZTA) depara-se com barreiras consideráveis. A transição de um modelo de perímetro tradicional para um modelo de confiança zero acarreta impactos significativos na infraestrutura e na gestão operacional de um sistema [14,11].

- **Aumento da Latência na Rede:** Ocorre um aumento inerente da latência derivado dos processos de verificação contínua. Como cada pedido de acesso e cada sessão são constantemente intercetados, reavaliados e autenticados pelo Motor de Políticas (*Policy Engine*), o processamento criptográfico e a comunicação adicional introduzem atrasos, afetando o desempenho de aplicações em tempo real.
- **Integração com Sistemas Legados:** Verifica-se uma dificuldade forte em integrar estes novos paradigmas com sistemas legados (*legacy systems*). Muitas infraestruturas antigas não foram desenhadas para suportar APIs modernas, esquemas de microsegmentação e/ou os protocolos de autenticação dinâmica (como MFA ou SSO baseados na *cloud*) exigidos pela ZTA, tornando a migração arquitetural complexa, fragmentada e dispendiosa.

- **Complexidade de Gestão de Políticas:** Existe uma elevada complexidade associada à gestão de políticas de acesso que operam de forma tão dinâmica e granular. A necessidade de definir, atualizar e monitorizar dezenas de milhares de regras baseadas em atributos (ABAC) ou em contexto em tempo real exige ferramentas de automação avançadas e pode sobrecarregar severamente as equipas de administração e operações de segurança (SecOps).

6 Estudo de Caso: Implementação em Ecossistemas Robustos e Distribuídos (IoMT)

A Internet das Coisas Médicas (IoMT) combinada com *Federated Learning* (FL) é um cenário exigente para a ZTA, por reunir três características: dados altamente sensíveis, dispositivos com recursos limitados e necessidade de resposta em tempo real. Almuseelem propõe, para este contexto, uma arquitetura em camadas que combina *edge computing*, FL e uma camada de autenticação *zero trust*, destinada a decidir onde executar as tarefas dos dispositivos médicos sem comprometer a latência nem a segurança [15]. Os dispositivos, com poucos recursos, realizam apenas pré-processamento e autenticação leve, enquanto as tarefas são executadas ou descarregadas nos servidores *edge* dos hospitais. Estes treinam modelos locais que são agregados num servidor *cloud* através de FL, sem partilha dos dados em bruto. Um Orquestrador *Zero Trust* (ZTO) trata da autenticação mais pesada dos servidores *edge* e *cloud* [15].

Este caso permite observar como os princípios da ZTA se comportam num ambiente crítico, e evidencia os desafios de implementação discutidos na Secção 5. A verificação rigorosa em várias camadas de comunicação entra em conflito com as limitações de processamento e de bateria dos dispositivos, e os mecanismos descentralizados de gestão de confiança introduzem sobrecarga e problemas de escalabilidade, o que se traduz numa latência difícil de conciliar com o tratamento de emergências médicas [15].

- **Camada de Dispositivos (*Device Layer*):** Inclui dispositivos médicos (MDs) heterogéneos e com recursos limitados, como equipamentos de saúde vestíveis, implantáveis, de diagnóstico e inteligentes dentro do hospital, servindo cada um diferentes propósitos de aplicação. Os dispositivos IoMT com recursos limitados recolhem dados fisiológicos, emocionais e relacionados com a atividade, com distribuições de dados e requisitos computacionais variáveis. Além disso, computações mínimas no dispositivo, como pré-processamento e autenticação leve, são realizadas nos MDs.
- **Camada de Comunicação (*Communication Layer*):** Envolve a infraestrutura de rede que liga os MDs, os Servidores Edge (ESs) e a *cloud*. O Wi-Fi (IEEE 802.11) atua como protocolo de comunicação principal entre MDs e ESs, fornecendo conectividade sem fios de alta velocidade com largura de banda entre 100 e 1000 Mbps, oferecendo baixa latência. O *Multi-Protocol Label Switching* (MPLS) com largura de banda de 10 a 100 Mbps é utilizado para a comunicação entre ESs e o Servidor *Cloud* (CS), oferecendo uma solução de rede de alto desempenho, escalável e segura. A comunicação *edge-to-edge* também pode ser facilitada de forma eficiente utilizando MPLS.
- **Camada de Edge (*Edge Layer*):** Esta camada inclui múltiplos ESs com capacidades de recursos variáveis instalados em diferentes instalações hospitalares. Cada hospital é controlado por um ES, que executa as tarefas ou as descarrega noutros ESs com base nas suas capacidades computacionais. Como os MDs têm recursos limitados, as tarefas são enviadas para os ESs através de uma estação base (BS) para pré-processamento adicional e geração de um modelo local utilizando um modelo de Aprendizagem por Reforço (RL).
- **Camada de Federated Learning (*FL Layer*):** Envolve o processo de FL para recolher e agregar parâmetros de modelos locais periodicamente a partir de vários ESs, sem partilhar a totalidade dos dados, para gerar um modelo global. Ajuda na tomada

de decisões relacionadas com o descarregamento de tarefas para outros ES ou a sua execução local no ES ligado ao hospital, com base na disponibilidade de recursos e requisitos da tarefa.

- **Camada de Cloud (Cloud Layer):** A camada superior da arquitetura inclui um servidor federado ou servidor *cloud* (CS). O CS possui um motor de agregação para criar um modelo global a partir de parâmetros locais, armazenamento a longo prazo para dados e análise, uma unidade de seleção de clientes para escolher os participantes (ESs) em cada ronda de FL com base na disponibilidade de recursos, confiança e condições da rede, bem como uma unidade de alocação e otimização para gerir recursos *cloud* e otimizar a eficiência do treino FL.
- **Camada de Autenticação e Zero Trust (Zero Trust and Authentication Layer):** Implementa autenticação leve para a verificação rigorosa da identidade dos MDs. Inclui também um Orquestrador Zero Trust (ZTO) para lidar com a autenticação pesada dos ESs e do CS.
- **Camada de Resposta em Tempo Real (Real-time Response Layer):** Esta camada final lida com tarefas de emergência que requerem respostas imediatas, tais como alertas de emergência para hospitais ou profissionais de saúde.

7 Conclusão

A ZTA representa uma mudança importante na segurança das redes, se baseando no princípio de “nunca confiar, verificar sempre”. O modelo garante acessos mais seguros através da validação contínua e do princípio do menor privilégio, sendo útil em situações como acesso remoto, gestão de terceiros e proteção contra ransomware. Apesar das suas vantagens, a implementação pode aumentar a latência, dificultar a integração com sistemas antigos e tornar a gestão das políticas de acesso mais complexa.

Referências

1. Kang, H., Liu, G., Wang, Q., Meng, L., Liu, J.: Theory and application of zero trust security: A brief survey. *Entropy* **25**(12) (2023) 1595
2. IBM: What is the internet of things (iot)? | ibm (2024) Accessed: 2026-10-03.
3. Kindervag, J.: No more chewy centers: Introducing the zero trust model of information security. Technical report, Forrester Research (2010)
4. Rose, S., Borchert, O., Mitchell, S., Connelly, S.: Zero trust architecture. Technical Report SP 800-207, NIST (2020)
5. Ward, R., Beyer, B.: Beyondcorp: A new approach to enterprise security. *login*: **39**(6) (2014) 6–11
6. Fernandez, E.B., Brazhuk, A.: A critical analysis of zero trust architecture (zta). *Computer Standards & Interfaces* **89** (2024) 103832
7. Rousseau, D.M., Sitkin, S.B., Burt, R.S., Camerer, C.: Not so different after all: A cross-discipline view of trust. *Academy of Management Review* **23**(3) (1998) 393–404
8. Govindan, K., Mohapatra, P.: Trust computations and trust dynamics in mobile adhoc networks: A survey. *IEEE Communications Surveys & Tutorials* **14**(2) (2011) 279–298
9. Burns, C., Mearns, K., McGeorge, P.: Explicit and implicit trust within safety culture. *Risk Analysis* **26**(5) (2006) 1139–1150
10. Pearson, S., Mont, M.C., Crane, S.: Persistent and dynamic trust: Analysis and the related impact of trusted platforms. In: *Trust Management (iTrust 2005)*. (2005)
11. Dhiman, P., Saini, N., Gulzar, Y., Turaev, S., Kaur, A., Nisa, K.U., Hamid, Y.: A review and comparative analysis of relevant approaches of zero trust network model. *Sensors* **24**(4) (2024) 1328
12. IEEE Digital Privacy: What is zero trust architecture? (2024) Accessed: 2026-10-05.
13. Ge, Y., Zhu, Q.: Gazeta: Game-theoretic zero-trust authentication for defense against lateral movement in 5g iot networks. *IEEE Transactions on Information Forensics and Security* **19** (2024) 540–554

14. He, Y., Huang, D., Chen, L., Ni, Y., Ma, X.: A survey on zero trust architecture: Challenges and future trends. *Wireless Communications and Mobile Computing* **2022** (2022) 6476274
15. Almuseelem, W.: Secure latency-aware task offloading using federated learning and zero trust in edge computing for iomt. *IEEE Access* **13** (2025) 117808–117830